

ЗВІТ

з лабораторної роботи № 2

з дисципліни «Проектування, розробка і реалізація криптографічних систем»

на тему: «Дослідження реалізацій протоколів IPsec»

Виконала:
студентка групи ФІ-52мн
Балацька Вікторія

Київ — 2026

1. Мета роботи

Дослідження архітектури та криптографічних механізмів IPsec, принципів організації захищених мережових з'єднань та особливостей застосування IPsec у різних мережових сценаріях.

2. Відповіді на питання щодо архітектури та механізмів IPsec

2.1. Призначення IPsec і рівень мережової моделі

IPsec (архітектура — RFC 4301) — набір протоколів для захисту IP-трафіку: забезпечує конфіденційність, цілісність і автентичність походження пакетів, захист від повторного відтворення (anti-replay) та обмежену конфіденційність потоку трафіку. Функціонує на **мережевому рівні** (рівень 3 моделі OSI, рівень Internet стеку TCP/IP) і діє як «захищений IP»: захист застосовується до пакета незалежно від транспортного протоколу та застосунку. Звідси головна практична перевага — прозорість: TCP, UDP, ICMP і будь-які застосунки захищаються без їх зміни, а на шлюзі можна захистити трафік цілої мережі, не встановлюючи нічого на робочі станції. Недолік того самого рівня — IPsec автентифікує вузли (IP-адреси, шлюзи), а не користувачів чи застосунки.

2.2. Функції IKEv2 та ESP і їх взаємодія

IPsec розділено на дві площини. **IKEv2** (RFC 7296, UDP 500/4500) — площина керування: взаємна автентифікація сторін (сертифікати X.509, PSK або EAP), узгодження криптографічних алгоритмів, обмін ключами Діффі–Геллмана, генерація ключового матеріалу, створення, оновлення (rekey) і видалення SA, узгодження селекторів трафіку, перевірка «живості» пари (DPD), виявлення NAT, видача віртуальної IP-адреси клієнту. **ESP** (RFC 4303, IP-протокол 50) — площина даних: шифрування і автентифікація кожного пакета на ключах, які встановив IKE.

Обмін IKEv2	Повідомлення / вміст	Результат
IKE_SA_INIT (1 пара)	SA (пропозиції алгоритмів), KE (відкритий ключ DH/ECDH), Nonce, NAT_DETECTION_*	Узгоджено алгоритми, спільний секрет DH → ключі IKE SA (SKEYSEED). Наступні повідомлення шифруються.
IKE_AUTH (1 пара)	Idi/IDr, CERT, AUTH (підпис або MAC над повідомленнями), SA для ESP, TSi/TSr (селектори трафіку), CP (конфігурація)	Взаємна автентифікація; створено першу пару Child SA (ESP).
CREATE_CHILD_SA	SA, Nonce, [KE — для PFS], TS	Додаткові Child SA або періодичне оновлення ключів ESP та самої IKE SA.
INFORMATIONAL	Delete, Notify, порожнє повідомлення (DPD)	Видалення SA, повідомлення про помилки, перевірка доступності пари.

Таблиця 1 — Обміни IKEv2

Взаємодія: IKEv2 за 2 обміни (4 повідомлення) встановлює IKE SA та першу пару Child SA і записує в ядро (SAD) алгоритми, ключі, SPI та селектори. Далі ESP обробляє кожен пакет самостійно, без участі IKE; IKE залишається фоновим контрольним каналом — оновлює ключі до закінчення строку життя SA, виявляє обрив, видаляє SA. Такий поділ дає змогу виконувати важку криптографію з відкритим ключем рідко, а швидко симетричну — для кожного пакета (часто апаратно).

2.3. *Security Association (SA)*

SA — односпрямована «угода» про параметри захисту трафіку між двома вузлами. Кожна вхідна SA однозначно ідентифікується **SPI** (32-бітовим індексом у заголовку ESP), разом з адресою призначення і протоколом (ESP/AH). SA характеризують: протокол і режим (транспорт/тунель); алгоритми і ключі шифрування та цілісності; адреси кінцевих точок тунелю; селектори трафіку (які пакети належать SA); лічильник послідовних номерів і вікно anti-replay; строк життя (у секундах і байтах); параметри NAT-T (порти інкапсуляції).

Чому потрібно кілька SA. SA односпрямована: для двостороннього обміну потрібна пара Child SA — «A→B» і «B→A», з різними SPI і різними ключами (використання одного ключа в обох напрямках призвело б до повторного використання nonce/IV в AES-GCM і дозволило б відбивати пакети відправнику). Крім того, окремо існує IKE SA (двонаправлена, для керування), а під час оновлення ключів деякий час одночасно діють стара і нова пари. Для різних класів трафіку (різні підмережі, QoS) також створюють окремі пари SA.

2.4. *Бази SPD та SAD*

SPD (Security Policy Database) — впорядкований набір політик, що визначає, **що робити** з кожним пакетом за його селекторами (адреси, протокол, порти): PROTECT (захистити IPsec, з вимогами до SA), BYPASS (пропустити без захисту) або DISCARD (відкинути). SPD перевіряється і для вихідних пакетів (чи треба шифрувати), і для вхідних (чи мав цей пакет прийти захищеним — це запобігає підміні відкритими пакетами). **SAD (Security Association Database)** — містить **як захищати**: активні SA з ключами, алгоритмами, лічильниками. Вихідний пакет: SPD → PROTECT → пошук SA в SAD (якщо немає — IKE отримує запит і створює її). Вхідний ESP-пакет: SAD за SPI → розшифрування і перевірка → звірка з SPD, що пакет відповідає селекторам SA. Третя база, **PAD (Peer Authorization Database)**, пов'язує автентифіковану ідентичність пари з тим, які SA їй дозволено створювати. У Linux SPD і SAD видимі командами `ip xfrm policy` та `ip xfrm state`.

2.5. Транспортний і тунельний режими

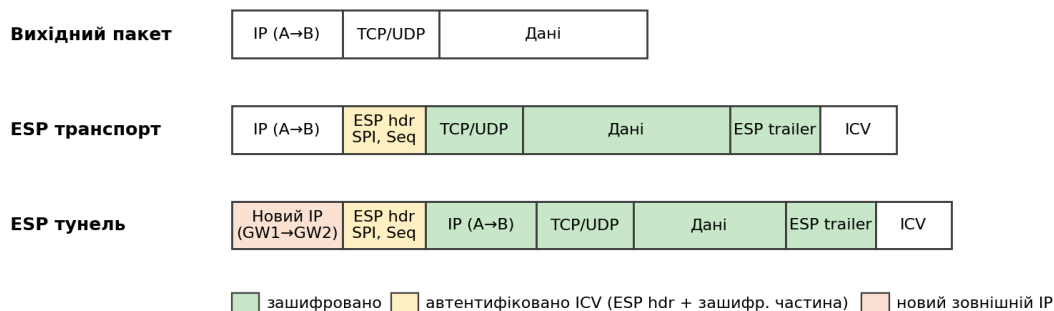


Рисунок 1 — Структура пакета ESP у транспортному та тунельному режимах

У **транспортному режимі** заголовок ESP вставляється між вихідним IP-заголовком і даними транспортного рівня: захищається корисне навантаження, а оригінальні IP-адреси залишаються відкритими. Кінцевими точками IPsec є самі вузли-комунікатори. Сценарії: захист host-to-host (сервер–сервер, сервер БД–застосунок), захист інших тунелів (L2TP/IPsec, GRE over IPsec), кластерний трафік.

У **тунельному режимі** весь вихідний IP-пакет шифрується і вкладається в новий IP-пакет з адресами шлюзів. Кінцеві точки IPsec (шлюзи) відрізняються від кінцевих точок комунікації. Внутрішні адреси, протоколи й порти приховані. Сценарії: site-to-site VPN між мережами, віддалений доступ (клієнт отримує внутрішню адресу), з'єднання з хмарою. Тунельний режим обов'язковий, коли хоча б одна сторона — шлюз, що захищає трафік інших вузлів.

2.6. АН і ESP; чому використовують ESP

АН (Authentication Header, RFC 4302, протокол 51) забезпечує лише цілісність і автентичність, але поширює її також на незмінні поля зовнішнього IP-заголовка (зокрема адреси). **ESP** забезпечує конфіденційність, цілісність і автентичність даних (у режимі AEAD — одночасно), але не захищає зовнішній IP-заголовок. ESP домінує, тому що: (1) конфіденційність потрібна майже завжди, а ESP може працювати й без шифрування (ESP-NULL), покриваючи задачу АН; (2) АН принципово несумісний з NAT — зміна адреси на NAT-пристрої руйнує перевірку ICV, а ESP можна інкапсулювати в UDP (NAT-T); (3) захист зовнішнього заголовка має малу практичну цінність — у тунельному режимі внутрішній заголовок і так захищений ESP; (4) сучасні AEAD-алгоритми (AES-GCM, ChaCha20-Poly1305) реалізовані для ESP, з апаратним прискоренням. RFC 8221 визначає АН як той, що не рекомендується до впровадження в нових системах там, де можна застосувати ESP.

2.7. Проблема NAT і NAT Traversal

NAT змінює IP-адреси (і порти — у PAT) у пакетах. Для IPsec це створює проблеми: (1) АН-пакети стають недійсними, оскільки адреси входять до ICV; (2) ESP

не має портів — PAT не може розрізнити кілька клієнтів за однією адресою і коректно зіставити відповідь, багато NAT-пристроїв просто відкидають протокол 50; (3) у транспортному режимі змінена адреса ламає контрольні суми TCP/UDP; (4) IKE-ідентифікатори, прив'язані до IP-адрес, не збігаються.

NAT-T (RFC 3948, механізм виявлення — у RFC 7296): у IKE_SA_INIT обидві сторони надсилають хеші своїх адрес і портів (NAT_DETECTION_SOURCE_IP / DESTINATION_IP). Невідповідність хешів означає наявність NAT на шляху; тоді IKE переходить з порту 500 на UDP 4500, а ESP-пакети інкапсулюються в UDP 4500 (з 4-байтовим нульовим маркером, що відрізняє їх від IKE). Тепер у пакета є UDP-порти, і NAT/PAT обробляє його як звичайний UDP-трафік. Сторона за NAT надсилає NAT-keepalive (зазвичай кожні 20 с), щоб зберегти запис у таблиці трансляції. Ціна — додаткові 8 байтів заголовка і менший ефективний MTU.

2.8. Perfect Forward Secrecy (PFS) в IPsec

PFS означає, що ключі кожної SA виводяться з нового ефемерного обміну DH/ECDH, а не лише з раніше встановленого секрету. В IKEv2 ключі першої Child SA виводяться з ключового матеріалу IKE SA (SK_d), а для наступних Child SA і при оновленні ключів PFS вмикається включенням payload KE у CREATE_CHILD_SA (у конфігурації — група DH у пропозиції ESP, напр. aes256gcm16-x25519). Також оновлення самої IKE SA завжди виконується з новим DH. **Від чого захищає:** компрометація довготривалих облікових даних (закритого ключа сертифіката, PSK) або ключів однієї SA не дозволяє розшифрувати записаний раніше трафік інших SA — кожен сеанс треба «ламати» окремо. Також обмежується шкода від атак на зразок «зберегти зараз, розшифрувати потім». PFS **не захищає** від активного MITM, якщо зломисник вже має облікові дані, — лише від ретроспективного розшифрування.

3. Аналіз сценаріїв застосування IPsec

Для всіх сценаріїв використано IKEv2 з ESP. Рекомендовані алгоритми (згідно з RFC 8221, RFC 8247): ESP — AES-256-GCM (або ChaCha20-Poly1305); IKE — AES-256-GCM, PRF HMAC-SHA-384, група DH — curve25519 або ECP-384; автентифікація — сертифікати X.509 (ECDSA або RSA ≥ 3072).

3.1. Сценарій 1: з'єднання двох офісів (site-to-site)

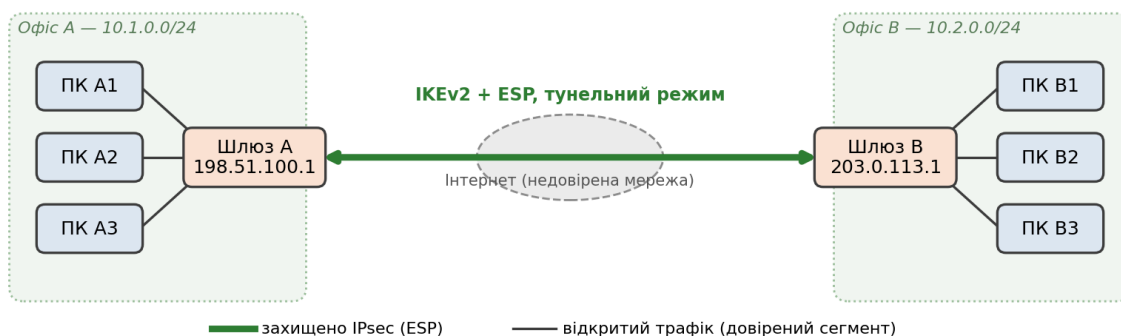


Рисунок 2 — Схема з'єднання двох офісів

Параметр	Рішення
Кінцеві точки IPsec	Шлюз А ↔ Шлюз В (маршрутизатори/міжмережеві екрани на межі офісів)
Режим	Тунельний (шлюзи захищають трафік інших вузлів, адреси LAN приватні)
Захищений трафік	Увесь трафік між 10.1.0.0/24 і 10.2.0.0/24 на ділянці Інтернету (селектори TS: 10.1.0.0/24 ↔ 10.2.0.0/24). Трафік в Інтернет і всередині LAN у тунель не потрапляє.

Обґрунтування: вимога «без додаткового ПЗ на робочих станціях» виконується лише шлюзовою схемою — для ПК тунель прозорий, вони користуються звичайною маршрутизацією. Тунельний режим необхідний, бо IPsec-кінцеві точки (шлюзи) не збігаються з вузлами-комунікаторами і приватні адреси мають передаватися через Інтернет усередині захищеного пакета.

3.2. Сценарій 2: підключення віддаленого працівника (remote access)



Рисунок 3 — Схема віддаленого доступу

Параметр	Рішення
Кінцеві точки IPsec	Пристрій працівника (вбудований IKEv2-клієнт Windows/macOS/iOS/Android або strongSwan) ↔ VPN-концентратор на периметрі організації
Режим	Тунельний: клієнт отримує віртуальну внутрішню адресу (IKEv2 Configuration Payload), внутрішні пакети інкапсулюються в ESP

Параметр	Рішення
Захищений трафік	Увесь трафік від клієнта до внутрішніх мереж організації (split tunnel) або весь трафік пристрою (full tunnel, 0.0.0.0/0) — для контролю доступу в Інтернет через корпоративні засоби

Обґрунтування: пристрій працівника сам є кінцевою точкою, бо іншого довіреного вузла поруч немає. Працівник зазвичай перебуває за NAT (дім, готель, мобільна мережа) — необхідний NAT-T (UDP 4500). Автентифікація: сертифікат пристрою та/або EAP (EAP-TLS, EAP-MSCHAPv2 з RADIUS/MFA) — прив'язка до облікового запису користувача. Механізм MOBIKE (RFC 4555) дозволяє зберегти тунель при зміні мережі (Wi-Fi → LTE).

3.3. Сценарій 3: захищений зв'язок між двома серверами (host-to-host)



Рисунок 4 — Схема host-to-host

Параметр	Рішення
Кінцеві точки IPsec	Сервер А ↔ Сервер В (IPsec безпосередньо в ОС серверів, напр. strongSwan/Libreswan на Linux, Windows IPsec)
Режим	Транспортний
Захищений трафік	Лише трафік між IP-адресами двох серверів (за потреби — лише конкретні порти, напр. TCP 5432); інший трафік серверів не змінюється

Обґрунтування: кінцеві точки IPsec збігаються з кінцевими точками комунікації, тому новий IP-заголовок не потрібен — транспортний режим економить 20 (IPv4) / 40 (IPv6) байтів на пакет і не вимагає окремої адресації тунелю. Захист «наскрізний» — від ОС до ОС, без довірених проміжних шлюзів, що відповідає вимозі захистити трафік саме між цими вузлами в недовірєній мережі.

3.4. Сценарій 4: центральний офіс і декілька філій (hub-and-spoke)

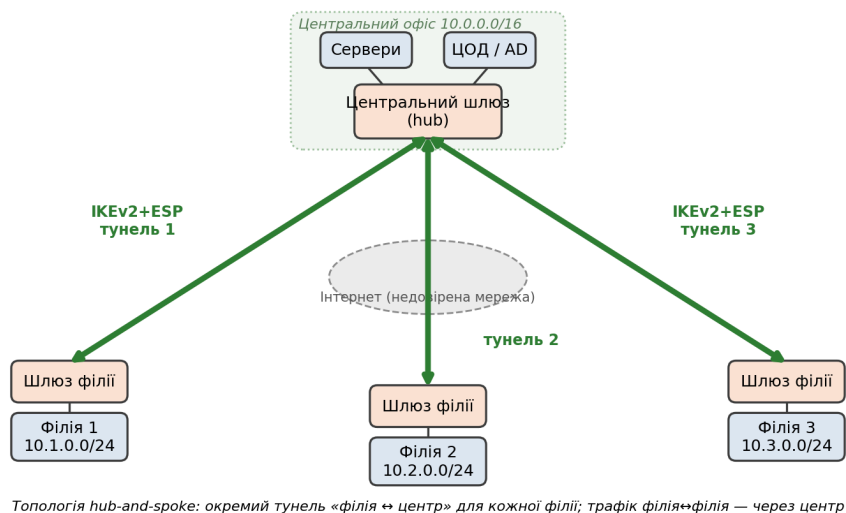


Рисунок 5 — Схема «центральный офіс — філії»

Параметр	Рішення
Кінцеві точки IPsec	Шлюз кожної філії ↔ центральний шлюз (hub). N філій — N тунелів (IKE SA + пари Child SA)
Режим	Тунельний
Захищений трафік	Трафік між мережею кожної філії і мережею центрального офісу; за потреби — також філія↔філія транзитом через центр (селектори філії включають мережі інших філій)

Обґрунтування: топологія «зірка» масштабується лінійно (N тунелів замість $N \cdot (N-1)/2$ у повній зв'язності), централізує політики, моніторинг і доступ до ресурсів ЦОД. Для полегшення масштабування доцільні route-based VPN (віртуальні інтерфейси VTI/XFRM) з динамічною маршрутизацією (OSPF/BGP) та автентифікація сертифікатами з корпоративної PKI (новій філії достатньо видати сертифікат). Філії з динамічними адресами або за NAT ініціюють з'єднання самі (NAT-T). Для прямого зв'язку між філіями можна використовувати DMVPN-подібні рішення (динамічні spoke-to-spoke тунелі).

3.5. Сценарій 5: локальна мережа та хмарна інфраструктура (hybrid cloud)

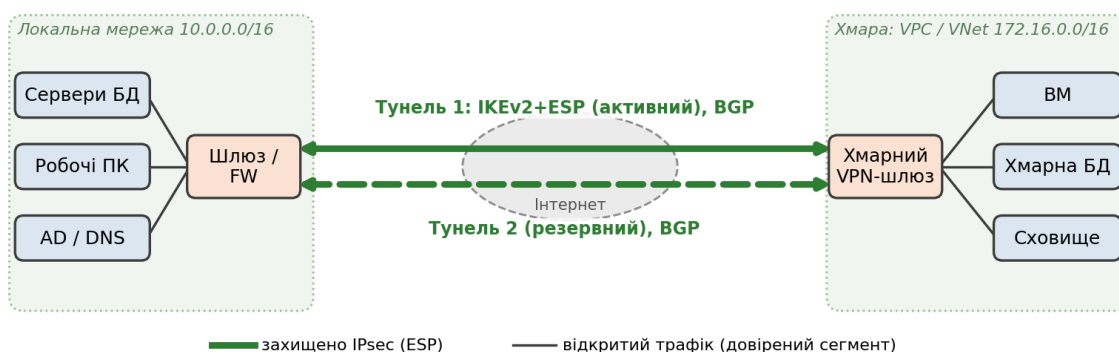


Рисунок 6 — Схема з'єднання локальної мережі з хмарою

Параметр	Рішення
Кінцеві точки IPsec	Периметровий шлюз локальної мережі ↔ керований VPN-шлюз хмарного провайдера (AWS Site-to-Site VPN, Azure VPN Gateway, Google Cloud HA VPN)
Режим	Тунельний, route-based; два тунелі до різних адрес хмарного шлюзу для відмовостійкості, маршрути обмінюються через BGP
Захищений трафік	Трафік між локальними підмережами 10.0.0.0/16 і підмережами VPC/VNet 172.16.0.0/16. Звернення до публічних API хмари йдуть окремо через TLS

Обґрунтування: хмарні провайдери надають керований шлюз саме як IPsec/IKEv2-ендпоінт, сумісний з обладнанням будь-якого виробника. Фактично це варіант site-to-site, де «офіс В» — віртуальна мережа. Тунельний режим обов'язковий, бо захищаються мережі, а не окремі вузли. Два тунелі потрібні, оскільки провайдер оновлює свої шлюзи по черзі, а BGP автоматично перемикає трафік. Хмарний шлюз часто стоїть за NAT, тому підтримка NAT-T обов'язкова.

4. Детальний аналіз індивідуального сценарію

Як індивідуальний варіант розглянуто **сценарій 1** — з'єднання двох офісів (site-to-site VPN). Схему наведено на рисунку 2.

4.1. Вибір режиму

Обрано **тунельний режим**. Кінцеві точки IPsec — шлюзи, а кінцеві точки комунікації — ПК усередині LAN, тобто вони не збігаються. Транспортний режим захищає лише навантаження пакета, адресованого самому вузлу IPsec, і не може передати пакет з адресою 10.1.0.15 через Інтернет. Тунельний режим вкладає весь вихідний пакет (з приватними адресами) у новий пакет «198.51.100.1 → 203.0.113.1», тому (1) приватні адреси маршрутизуються через публічну мережу, (2) внутрішня адресація і структура мереж приховані, (3) ПК не потребують конфігурації.

4.2. Між якими вузлами встановлюються SA

SA	Між якими вузлами	Напрямок / призначення
IKE SA (1)	Шлюз А ↔ Шлюз В (UDP 500/4500)	Двонаправлена; захищений канал керування
Child SA (ESP) «A→B»	Шлюз А → Шлюз В, SPI обирає В	Трафік 10.1.0.0/24 → 10.2.0.0/24
Child SA (ESP) «B→A»	Шлюз В → Шлюз А, SPI обирає А	Трафік 10.2.0.0/24 → 10.1.0.0/24

Жодних SA з ПК не встановлюється — вони про IPsec «не знають». Під час планового оновлення ключів тимчасово існує ще одна пара Child SA. Приклад конфігурації шлюзу А (strongSwan, swanctl.conf, скорочено):

```
connections {
  office-a-b {
    version = 2
    local_addrs = 198.51.100.1
    remote_addrs = 203.0.113.1
    proposals = aes256gcm16-prfsha384-x25519      # алгоритми IKE SA
    local { auth = pubkey certs = gw-a.crt id = gw-a.example.com }
    remote { auth = pubkey id = gw-b.example.com }
    children {
      lan-a-b {
        local_ts = 10.1.0.0/24                    # селектори трафіку -> SPD
        remote_ts = 10.2.0.0/24
        mode = tunnel
        esp_proposals = aes256gcm16-x25519        # ESP + PFS при rekey
        rekey_time = 1h
        dpd_action = restart
        start_action = trap                       # SA створюється за першим пакетом
      }
    }
  }
}
```

Лістинг 1 — Приклад конфігурації IKEv2-шлюзу для сценарію 1

4.3. Роль IKEv2

- **Узгодження параметрів:** IKE_SA_INIT — вибір алгоритмів з пропозицій (AES-GCM, PRF SHA-384, X25519).
- **Обмін ключами:** ECDH X25519 → SKEYSEED → ключі IKE SA та ключ SK_d для виведення ключів ESP.
- **Взаємна автентифікація шлюзів:** IKE_AUTH — кожен шлюз підписує стенограму закритим ключем і пред'являє сертифікат; інша сторона перевіряє сертифікат щодо корпоративного ЦС і відповідність ID. Це захищає від підставного шлюзу (MITM).
- **Узгодження селекторів трафіку (TSi/TSr)** — які мережі захищаються; результат записується в SPD/SAD обох шлюзів.
- **Виявлення NAT (NAT_DETECTION)** і, за потреби, перехід на UDP 4500.
- **Підтримка протягом роботи:** періодичне оновлення ключів з PFS (CREATE_CHILD_SA з KE), DPD, коректне видалення SA.

4.4. Функції ESP у схемі

- **Конфіденційність:** шифрування всього внутрішнього пакета (IP-заголовок з адресами ПК, TCP/UDP-заголовок, дані) алгоритмом AES-256-GCM.
- **Цілісність і автентичність походження:** тег ICV (GCM) — будь-яка модифікація пакета в Інтернеті або пакет не від шлюзу-партнера відкидаються.
- **Захист від повторного відтворення:** 32/64-бітовий порядковий номер і ковзне вікно anti-replay на приймальному шлюзі.
- **Інкапсуляція тунелю:** додавання зовнішнього IP-заголовка шлюзів і доставка пакета до протилежної мережі; на приймальному шлюзі — розпакування і перевірка відповідності селекторам (пакет з «чужою» внутрішньою адресою буде відкинуто).
- **Обмежена конфіденційність потоку:** можливе доповнення (TFC padding) для приховування реальних розмірів пакетів.

4.5. Що бачить сторонній спостерігач

Доступно спостерігачу в Інтернеті	Захищено IPsec
Публічні IP-адреси шлюзів (198.51.100.1, 203.0.113.1) — тобто факт зв'язку двох офісів	Внутрішні IP-адреси ПК і структура LAN
Протокол ESP (50) або UDP 4500, SPI, порядкові номери	Протоколи транспортного рівня та порти (які сервіси використовуються)
Розмір пакетів (з точністю до вирівнювання), час, інтенсивність і обсяг трафіку	Вміст даних: файли, пошта, облікові дані, запити до БД
Відкриті поля IKE_SA_INIT: запропоновані алгоритми, відкриті ключі DH (ID і сертифікати в IKE_AUTH вже зашифровано)	Ідентичності шлюзів у IKE_AUTH, селектори трафіку, ключі

Таблиця 2 — Інформація, доступна сторонньому спостерігачу

4.6. NAT і NAT-T

Якщо обидва шлюзи мають публічні статичні адреси (як на рис. 2), NAT на шляху відсутній і ESP передається як протокол 50; NAT-T не потрібен, але обидві сторони все одно його підтримують і автоматично вмикають. NAT **можливий і не заважає**: (1) у локальних мережах — трансляція для виходу ПК в Інтернет діє паралельно, але політики мають виключати трафік між офісами з NAT (правило «по-NAT» до IPsec-обробки), інакше пакет не відповідатиме селекторам SA; (2) якщо шлюз офісу стоїть за NAT провайдера (CGNAT, приватна адреса на WAN) — IKEv2 виявить NAT і перейде на ESP-in-UDP 4500, тоді NAT-T **необхідний**, а шлюз за NAT має бути ініціатором з'єднання. Для повністю прямого з'єднання без NAT-T достатньо відкрити на межі UDP 500 і протокол ESP.

4.7. Загрози, які усуває IPsec, і від яких не захищає

Усуває / знижує	Не захищає
Перехоплення і прослуховування трафіку між офісами (у провайдера, в точці обміну трафіком)	Атаки зсередини LAN: скомпрометований ПК або зловмисний співробітник — трафік до шлюзу не зашифрований
Модифікацію, впровадження та підміну пакетів у транзиті	Шкідливе ПЗ та експлуатацію вразливостей застосунків — тунель доставить шкідливий трафік так само надійно
Підміну шлюзу-партнера (MITM) — за умови взаємної автентифікації сертифікатами	Компрометацію самого шлюзу, його ключів або слабкий PSK (офлайн-перебір)
Повторне відтворення пакетів (anti-replay)	DoS: переповнення каналу, флуд IKE_SA_INIT (частково пом'якшується cookie)
Розкриття внутрішньої адресації та використовуваних сервісів	Аналіз трафіку за обсягом, часом і фактом зв'язку між публічними адресами
Ретроспективне розшифрування записаного трафіку (за PFS)	Помилки конфігурації: надто широкі селектори, застарілі алгоритми, відсутність сегментації між офісами

Таблиця 3 — Загрози, що усуваються і не усуваються IPsec

Тому IPsec має доповнюватися міжмережовим екрануванням трафіку, що виходить з тунелю (принцип мінімальних привілеїв між мережами), захистом кінцевих вузлів, моніторингом і TLS на рівні застосунків для критичних сервісів.

5. Порівняння IPsec/IKEv2 та WireGuard

Критерій	IPsec / IKEv2	WireGuard
Загальна архітектура	Набір стандартів IETF (RFC 4301, 4303, 7296 та ін.). Розділення: IKE-демон у просторі користувача + ESP у ядрі (SPD/SAD, policy-based або route-based). Великий код і багато опцій.	Єдиний компактний протокол (~4 тис. рядків у ядрі Linux). Віртуальний мережевий інтерфейс; маршрутизація за «cryptokey routing» (AllowedIPs ↔ відкритий ключ пари). Не є стандартом IETF.
Встановлення та керування ключами	IKEv2: узгодження, взаємна автентифікація (X.509/PKI, PSK, EAP — у т. ч. облікові записи користувачів, RADIUS, MFA), відкликання сертифікатів, rekey з PFS, конфігурація клієнтів (віртуальна IP, DNS).	Статичні відкриті ключі Curve25519, які треба заздалегідь поширити між парами. Рукописання Noise_IK (1-RTT); сеансові ключі оновлюються кожні 2 хв. Немає PKI, користувачів, видачі адрес — це робиться зовнішніми засобами.
Криптографічні алгоритми	Широкий вибір: AES-GCM/CCM/CBC, ChaCha20-Poly1305, HMAC-SHA-2, групи DH MODP/ECP/Curve25519/448, RSA/ECDSA/EdDSA; з'являються постквантові гібридні обміни (RFC 9370, ML-KEM).	Фіксований набір: Curve25519 (ECDH), ChaCha20-Poly1305 (AEAD), BLAKE2s (хеш), SipHash, HKDF; опційний PSK для додаткового симетричного захисту.
Можливість вибору алгоритмів	Є: узгоджується під час IKE_SA_INIT/IKE_AUTH. Гнучкість і сумісність, відповідність вимогам (FIPS, HC3I), але ризик помилкової конфігурації та downgrade до слабких алгоритмів.	Немає (crypto-agility відсутня свідомо): менше помилок і атак downgrade, але для заміни алгоритму потрібна нова версія протоколу; складно виконати вимоги регуляторів щодо певних алгоритмів (напр., FIPS).

Критерій	IPsec / IKEv2	WireGuard
Робота в мережах із NAT	Через NAT-T (виявлення NAT, ESP-in-UDP 4500, keepalive). Працює, але додає складності; деякі мережі блокують UDP 500/4500.	Від початку лише UDP (порт довільний), роумінг пари за адресою останнього автентифікованого пакета, опційний PersistentKeepalive. Прозоро проходить NAT.
Складність конфігурації	Висока: узгодження пропозицій між різними виробниками, селектори, PKI, режими. Типові проблеми сумісності між вендорами.	Низька: кілька рядків (ключі, Endpoint, AllowedIPs). Просто аудитувати, але масштабне керування ключами потребує окремих інструментів (Tailscale, Netmaker тощо).
Типові сценарії	Site-to-site між обладнанням різних виробників, з'єднання з хмарними провайдерами, корпоративний віддалений доступ з вбудованими клієнтами ОС та інтеграцією з AD/RADIUS, host-to-host у транспортному режимі, регульовані середовища.	Віддалений доступ і mesh-мережі на Linux/сучасних ОС, зв'язок серверів і контейнерів, малі та середні VPN, мобільні клієнти (роумінг), середовища, де керування ключами централізоване інструментами.

Таблиця 4 — Порівняння IPsec/IKEv2 та WireGuard

Висновок щодо сценаріїв розділу 3:

Сценарій	Рекомендоване рішення	Обґрунтування
1. Два офіси	IPsec (WireGuard — допустима альтернатива)	Шлюзи/маршрутизатори будь-якого виробника підтримують IPsec, сертифікати PKI; WireGuard доцільний, якщо обидва шлюзи — Linux/сучасні маршрутизатори з його підтримкою.
2. Віддалений працівник	IPsec/IKEv2 в корпоративному середовищі; WireGuard — у простих/технічних командах	IKEv2 дає автентифікацію користувачів (EAP, RADIUS, MFA), видачу адрес, вбудований клієнт ОС. WireGuard кращий за продуктивністю і роумінгом, але потребує зовнішньої системи керування ключами й ідентичностями.
3. Два сервери	WireGuard або IPsec транспортний	Для двох Linux-серверів WireGuard найпростіший; IPsec у транспортному режимі — якщо потрібні стандарт, FIPS або ОС без WireGuard.
4. Центр і філії	IPsec	Масштабне керування через PKI, динамічна маршрутизація, сумісність з обладнанням у філіях, централізовані політики.
5. Локальна мережа і хмара	IPsec	Керовані VPN-шлюзи хмарних провайдерів (AWS, Azure, GCP) підтримують саме IPsec/IKEv2 з BGP; WireGuard можливий лише на власних ВМ-шлюзах, без SLA провайдера.

Таблиця 5 — Вибір технології для сценаріїв

6. Висновки

1. IPsec захищає трафік на мережевому рівні прозоро для застосунків. Його архітектура розділяє площину керування (IKEv2 — автентифікація, узгодження алгоритмів, обмін ключами, життєвий цикл SA) і площину даних (ESP —

шифрування, цілісність, anti-replay кожного пакета). Зв'язок між ними забезпечують SPD (що захищати) і SAD (як захищати), а SA є односпрямованими, тому для обміну потрібна їх пара.

2. Вибір режиму визначається тим, чи збігаються кінцеві точки IPsec з кінцевими точками комунікації: транспортний режим — для host-to-host (сценарій 3), тунельний — щойно хоча б одна сторона є шлюзом (сценарії 1, 2, 4, 5). У сучасних реалізаціях застосовується ESP з AEAD-шифрами; АН практично не використовується через несумісність з NAT і відсутність конфіденційності.

3. Детальний аналіз сценарію «два офіси» показав, що тунельний IPsec між шлюзами повністю приховує вміст, внутрішні адреси та сервіси, забезпечує взаємну автентифікацію шлюзів і PFS, не вимагаючи ПЗ на робочих станціях. Водночас спостерігачу залишаються видимими факт, обсяг і час обміну між офісами, а загрози всередині LAN, компрометація кінцевих вузлів і DoS потребують інших засобів захисту.

4. NAT-T вирішує проблему несумісності ESP з NAT шляхом інкапсуляції в UDP 4500 і є обов'язковим для віддаленого доступу та з'єднань із хмарою.

5. WireGuard простіший, швидший і менш схильний до помилок конфігурації, але не має узгодження алгоритмів, PKI та вбудованої автентифікації користувачів. IPsec/IKEv2 залишається доцільним для міжвендорних site-to-site, хмарних і корпоративних сценаріїв з централізованим керуванням (сценарії 1, 4, 5 і корпоративний варіант 2), а WireGuard — для зв'язку серверів, mesh-мереж і простого віддаленого доступу (сценарій 3, частково 2).

7. Перелік використаних джерел

1. Kent S., Seo K. Security Architecture for the Internet Protocol. RFC 4301. IETF, 2005. URL: <https://www.rfc-editor.org/rfc/rfc4301>
2. Kent S. IP Encapsulating Security Payload (ESP). RFC 4303. IETF, 2005.
3. Kent S. IP Authentication Header. RFC 4302. IETF, 2005.
4. Kaufman C. et al. Internet Key Exchange Protocol Version 2 (IKEv2). RFC 7296. IETF, 2014. URL: <https://www.rfc-editor.org/rfc/rfc7296>
5. Huttunen A. et al. UDP Encapsulation of IPsec ESP Packets. RFC 3948. IETF, 2005.
6. Eronen P. IKEv2 Mobility and Multihoming Protocol (MOBIKE). RFC 4555. IETF, 2006.
7. Wouters P. et al. Cryptographic Algorithm Implementation Requirements and Usage Guidance for ESP and AH. RFC 8221. IETF, 2017.
8. Nir Y. et al. Algorithm Implementation Requirements and Usage Guidance for IKEv2. RFC 8247. IETF, 2017.

9. Tjhai CJ. et al. Multiple Key Exchanges in IKEv2. RFC 9370. IETF, 2023.
10. Barker E. et al. Guide to IPsec VPNs. NIST SP 800-77 Rev. 1. 2020. URL: <https://doi.org/10.6028/NIST.SP.800-77r1>
11. Donenfeld J. A. WireGuard: Next Generation Kernel Network Tunnel. NDSS, 2017. URL: <https://www.wireguard.com/papers/wireguard.pdf>
12. WireGuard — Protocol & Cryptography. URL: <https://www.wireguard.com/protocol/>
13. strongSwan Documentation: swanctl.conf, IKEv2, NAT-T. URL: <https://docs.strongswan.org/>
14. AWS Site-to-Site VPN User Guide. URL: <https://docs.aws.amazon.com/vpn/>
15. Linux man pages: ip-xfrm(8). URL: <https://man7.org/linux/man-pages/man8/ip-xfrm.8.html>